

GZ: 2024-0.641.771 dated October 16, 2024 (Case Number: DSB-D550.769)

[Note from the editor: Names and companies, legal forms and product designations, addresses (including URLs, IP and email addresses), file numbers (and the like), statistical data, etc., as well as their initials and abbreviations may have been abbreviated and/or altered for pseudonymization reasons. Obvious spelling, grammar, and punctuation errors have been corrected.]

Criminal Finding

Accused legal entity: D**** GmbH (FN *32*9*n)

You have, as responsible parties in the sense of Art. 4 No. 7 of Regulation (EU) 2016/679 on the protection of natural persons in the processing of personal data, on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation, hereinafter: "GDPR"), OJ No. L 119 of May 4, 2016, p. 1, as amended, committed the following administrative offense:

The accused has named its commercial managing director (Dr. Edzard T***) as the data protection officer from May 19, 2021, to February 26, 2024 ("Offense Period"). There has been no assurance that the performance of other tasks and duties by the appointed person does not lead to a conflict of interest.

Therefore, the accused has violated its obligation under Art. 38 para. 6 GDPR by appointing its commercial managing director as the data protection officer, even though this person is subject to a conflict of interest due to his simultaneous role as managing director and data protection officer of the accused. As a result, the accused has appointed an unsuitable person as the data protection officer.

Administrative offenses according to:

Art. 37, 38 para. 6 in conjunction with Art. 83 para. 1 and 4 lit. a GDPR OJ L 2016/119, p. 1, as amended

Due to this administrative offense, the following penalty is imposed in accordance with Art. 83 GDPR:

Fine of Euro

according to

€ 5,000

Art. 83 para. 4 lit. a GDPR OJ L 2016/119, p. 1,

as amended

Furthermore, you are to pay according to § 64 of the Administrative Penal Act 1991 – VStG:

Euro as a contribution to the costs of the criminal proceedings, which is 10% of the fine,

but at least 10 Euro;

Euro as reimbursement of cash expenses for

500

The total amount to be paid (fine/costs/cash expenses) therefore amounts to

Euro

Payment deadline:

If no appeal is filed, this criminal finding is immediately enforceable. In this case, the total amount is to be paid within two weeks after the legal force takes effect to the account [account details shortened].

If payment is not made within this period, the total amount may be collected. In this case, a flat-rate cost contribution of five Euro is to be paid. If payment is still not made, the outstanding amount will be enforced.

Reasoning:

1.

The following decision-relevant facts are established based on the evidence procedure conducted:

1.1. The accused is a limited liability company registered under company registration number FN *32*9*n since May 19, 2021, with its registered office at M***platz *6, **** H***stadt.

1.2. Dr. Edzard T***, born on **.**.199*, has represented the accused independently as the commercial managing director since May 19, 2021, and was also a partner of the accused until February 17, 2023. The accused appointed Dr. Edzard T*** as the data protection officer. No notification of the appointed data protection officer to the data protection authority was made.

The accused has not taken any active steps – in the sense of outward-facing and visible measures – to ensure that the unified role of managing director and data protection officer in one person does not

lead to potential conflicts of interest.

1.3. Dr. Edzard T*** is a lawyer. He initially completed the diploma program and subsequently the doctoral program in law at the University of H***stadt. In addition, he holds an additional postgraduate degree in law from P*** University in W***, Scotland. Furthermore, he began a course for data protection officers at the Institute for Economic Development of the Austrian Chamber of Commerce (WIFI) but did not complete it.

1.4. The business sector of the accused is "Health Services and Diagnostic Laboratory." The purpose of the company was to contribute to combating the Covid-19 pandemic and

5,500

Ensuring the return to normalcy through orders from various clients, both from the private sector and from public authorities. In connection with the conclusion of cooperation agreements and participation in nationwide and federal tenders, the accused has steadily grown and represented one of the strongest COVID laboratories in Z*** in terms of capacity. The areas of activity of the accused have expanded over time due to the increasing volume of orders. The accused employed an average of 200 employees and conducted approximately 45,000 individual PCR analyses daily in the winter of 2021/22.

1.5. Since June 11, 2021, the accused has held the trades of "Organizational preparation and follow-up of virological testing on humans," "Business mediation in the form of mediating orders for the execution of (genetic) tests between prescribed doctors, approved laboratories, and private individuals who wish to use these services," "Trade businesses except for regulated trade businesses and trade agents," and "Transport of goods by motor vehicles or motor vehicles with trailers, whose maximum permissible total weight does not exceed 3,500 kg."

As of July 27, 2021, the accused also held the trade license for the business of "Manufacturing and preparation as well as rental of medical products, insofar as these activities do not fall under another regulated trade, and trade with and rental of medical products."

The accused has held the trade of "Manufacturing of pharmaceuticals and poisons and wholesale of pharmaceuticals and poisons" since August 21, 2021, and the trade of "Chemical laboratories" since August 16, 2021.

Finally, the accused relinquished all trade licenses on February 26, 2024, and has not exercised them since then.

1.6. After relinquishing the trade licenses, the accused stored the data records obtained in the course of their activities until deletion on March 21, 2024.

1.6. The revenue of the accused in 2023 amounted to approximately 4 million EUR according to their own statements, noting that there was no operational activity from June 2023 onwards.

2.

The findings are made based on the following evaluation of evidence:

2.1. The findings made regarding point 1.1. result from an official inquiry of the commercial register concerning the commercial register number *32*9*n with historical data.

2.2. The findings made regarding point 1.2. result on the one hand from an inquiry of the commercial register conducted on October 8, 2024, and on the other hand from the interrogation of the accused on May 23, 2023 (see here p. 4, GZ: D550.769; 2023-0.384.689).

The determination regarding the non-reporting of the Data Protection Officer arises from official knowledge and aligns with the statements made by the accused during the interrogation on May 23, 2023 (see here S. 4, GZ: D550.769; 2023-0.384.689).

The finding that the accused has not taken any active steps to prevent potential conflicts of interest arises from the response to the question posed during the interrogation of the accused on May 23, 2023, regarding how the managing director of the accused ensures "that there is no conflict of interest between your role as managing director in the company and as Data Protection Officer." Specifically, the accused responded as follows: "In this case, the client is a public authority. For the management of the Covid pandemic, it is more constructive for us to combine the Data Protection Officer and the managing director in one person. Especially since communication has taken place with the client or the public authority (Corona Control Center)." Active measures cannot be derived from this statement.

Furthermore, the accused, in her justification on September 3, 2024, merely stated that the dual role does not lead to any risk, as the managing director has the corresponding awareness and no constellation can be imagined in which a neglect of data protection obligations from a business perspective would have been indicated. However, from the declared lack of necessity for the personnel separation of the functions, no active step can be derived, and this was also not presented.

2.3. The findings regarding the academic background of the managing director (Point 1.3.) of the accused arise from the training documents submitted in the justification on July 3, 2023, from Mr. Dr. Edzard T***: Confirmation of the successful completion of the Bachelor's degree in Business Law from the University H***stadt; notice from the University H***stadt regarding the awarding of the academic degree: Master of Laws dated August 2, 2017; certificate of the First Diploma Examination from the University H***stadt dated January 29, 2015; certificate of the Second Diploma Examination from the University H***stadt dated February 7, 2017; certificate of the Third Diploma Examination from the University H***stadt; confirmation of the completion of the postgraduate program from P*** University dated November 5, 2020; certificate of the doctoral studies dated September 5, 2019; email dated March 7, 2022, regarding the information from WIFI Z*** about the start of the online course for the certified Data Protection Officer event.

2.4. Point 1.4. arises from an official inquiry of the commercial register regarding the company registration number *32*9*n with a cut-off date of October 8, 2024, examination of the annual financial statements and management report of the accused dated December 31, 2021, in conjunction with the statements made during the interrogation of the accused on May 23, 2023 (see here S. 4f, GZ: D550.769; 2023-0.384.689).

2.5. The findings regarding Point 1.5. arise from official inquiries regarding terminated trades of the accused in the Business Information System Austria (GISA) concerning the GISA numbers: [Note from the editor: a total of 7 GISA numbers listed].

2.6. Point 1.6. of the findings arises from the statement of the accused dated 03.09.2024 ("until 21.03.2024, only a storage of special categories of data took place"; "All data was deleted on 21.03.2024 at the request of the client of the accused person").

2.7. Point 1.7. of the findings arises from the document submission of the accused transmitted via email on 26.08.2024, which included an email from the managing director of the accused to the legal representatives describing the economic situation, a period overview for the period from 01 to 06 2024 concerning the accused, and a period overview for the period from 01 to 06 2024 concerning the shareholder of the accused.

3.

Legally, it follows:

3.1. Regarding the scope of application of the GDPR and the jurisdiction of the data protection authority

Art. 83 para. 4 lit. a GDPR stipulates that in the event of violations of the obligations under Art. 8, 11, 25 to 39, 42, and 43 GDPR, fines of up to 10,000,000 Euros or, in the case of a company, up to 2% of its total worldwide annual turnover from the previous financial year may be imposed, depending on which amount is higher.

According to § 22 para. 5 DSG, the jurisdiction for imposing fines against natural and legal persons for Austria as the national supervisory authority lies with the data protection authority.

Consequently, the data protection authority is also responsible for the present administrative offense proceedings.

3.2. Regarding the objective elements of the offense

Art. 37 GDPR regulates under which conditions the controller and the processor are required to appoint a data protection officer. Art. 37 GDPR applies to both controllers and processors independently (cf. König in Knyrim, DatKomm Art. 37 GDPR, para. 2).

The data protection officer holds a special role within the organization of the controller or the processor. He must always be involved in data protection-related issues and must have the necessary resources and access to fulfill his tasks (see Art. 38 GDPR). The tasks of the data protection officer are

defined in Art. 39 GDPR. The data protection officer serves as a "point of contact" for supervisory authorities and is obliged to "cooperate with the supervisory authority" (Art. 39 para. 1 lit. d and e GDPR).

The controller and the processor must appoint a data protection officer in any case "if the core activity of the controller or the processor consists of the extensive processing of special categories of data pursuant to Article 9 or of personal data concerning criminal convictions and offenses pursuant to Article 10" (Art. 37 para. 1 lit. c GDPR).

Recital 97 states that the "core activity" of a controller refers to "its main activities and not to the processing of personal data as a secondary activity." The "core activity" can be viewed as the essential workflows necessary to achieve the objectives of the controller or the processor. Nevertheless, the term "core activity" should not be interpreted to mean that it does not also extend to activities where the processing of data is an inseparable part of the activity of the controller or processor (cf. the guidelines of the Art. 29 Data Protection Working Party WP 243 rev.01, p. 8).

The guidelines on the data protection officer from the Art. 29 Data Protection Working Party (WP 243 rev.01, available among others at

https://www.dsb.gv.at/europa-internationales/europaeischer_datenschutzausschuss_edsa.html) do address this under 2.1.3, page 9, in footnote 14, by referring to Recital 91 and deriving that the term refers to "extensive processing operations [...], which are intended to process large amounts of personal data at regional, national, or supranational levels, could affect a large number of individuals and - for example, due to their sensitivity - are likely to pose a high risk."

Further indications of what is meant by "extensive data processing" can be found in accordance with the guidelines on data protection impact assessments (DPIA) and the question of whether processing within the meaning of Regulation 2016/679 "is likely to pose a high risk," WP 248 Rev.01 (available at https://www.dsb.gv.at/europa-internationales/europaeischer_datenschutzausschuss_edsa.html, p. 11), on page 9 of the guidelines on the data protection officer:

"In any case, WP29 recommends considering specifically the following factors when determining whether the processing in question is carried out on a large scale:

- a) the number of data subjects – either as a specific number or as a proportion of the relevant population
- b) the volume of data and/or the range of data being processed
- c) the duration or permanence of the data processing activity
- d) the geographical extent of the processing activity."

Rough indications of extensive processing can also be given by the number of employees (who are responsible for processing personal data) (cf. Löffler in Knyrim, Data Protection Law, para. 13.13).

Recital 91 denies "extensive" processing of personal data when it is carried out by a single doctor or other health professional or by a single lawyer.

As examples for the scope of Art. 37 para. 1 lit. c GDPR, health facilities, laboratories, counseling centers, victim protection facilities, and institutions for the resocialization of offenders (e.g., probation assistance, offender work) can be mentioned (cf. Bergauer in Jähnel, Commentary on the General Data Protection Regulation Art. 37 GDPR, para. 32).

In light of the fact that the core activity of the accused was that of a "diagnostic laboratory" in connection with the Covid pandemic in Austria (specifically: in the federal state of Z***), which conducted approximately 45,000 individual PCR analyses daily at least during the winter of 2021/22, thus processing a large number of health data according to Art. 9 para. 1 GDPR, that the accused employed an average of 200 employees, and that the areas of activity of the accused expanded over time due to the increasing order situation, it must be concluded that there is extensive processing of special categories of data according to Art. 9 GDPR and therefore a data protection officer must be mandatorily appointed. This was not disputed by the accused during the proceedings and, although it was not reported to the data protection authority, a data protection officer was appointed.

The only question—and the subject of dispute—is thus the period during which the obligation to appoint a data protection officer existed.

As can be seen from the findings, the accused submitted their business licenses on 26.02.2024, but claims that there has been no "operational activity" since June 2023 and thus implicitly argues that the necessity of appointing a data protection officer ended in June 2023.

The term "operational activity" is found in the Austrian AIFMG, but without a legal clarification of what it entails. In the AIFMD, this criterion is referred to as "general commercial or industrial purpose" (cf. Ley in Piska/Völkel, Blockchain rules, para. 12.15). However, the necessity of appointing a data protection officer is based solely on the "core activity" and not on any commercial or industrial purpose. Rather, the main activity can be derived from the acquired business licenses in conjunction with the business purpose. Thus, the short designation of the business sector, according to its own statement (§ 3 para. 1 no. 5 FBG), is intended to describe the actual area of activity of the legal entity (cf. Potyka in Straube/Ratka/Rauter, UGB I 4 § 3 FBG, para. 6). Therefore, it is not understandable why the core activity should no longer exist with the alleged end of operational business activity, and this is not based on any legal foundation.

As an interim result, it should therefore be noted that there was, in any case, an obligation to appoint a data protection officer during the period from 19.02.2021 to 26.02.2023 (hereinafter referred to as the "offense period").

In addition to the mandatory appointment, it should also be considered that when appointing the data protection officer, the requirements of Art. 38 GDPR ("Position of the Data Protection Officer") must be taken into account.

****Data Protection Officer****

sufficiently

fulfilled

will be.

Overall,

Art. 38

GDPR

is intended to enable

the Data Protection Officer to fulfill his tasks, as already mentioned at the outset, not only independently but also effectively (cf. König in Knyrim, DatKomm Art. 38 GDPR, para. 1).

Art. 38 para. 6 GDPR stipulates that the Data Protection Officer may perform other tasks and duties. However, the controller or the processor must ensure that such tasks and duties do not lead to a conflict of interest (cf. König in Knyrim, DatKomm Art. 38 GDPR). When such a "conflict of interest" exists is not defined in the GDPR itself.

In general, conflicts of interest can arise either from the nature of the activity or from the fact that due to additional tasks and duties, there is no longer time to perform the tasks of the Data Protection Officer according to Art. 39 GDPR (cf. König in Knyrim, DatKomm Art. 38 GDPR, para. 35).

The CJEU has already commented on the question of whether a conflict of interest exists in the sense of Art. 38 para. 6 sentence 2 in its judgment C-453/21 of 09.02.2023, when the Data Protection Officer also holds the position of chairperson of the works council established at the responsible entity, stating that "it follows from the wording of the provision, firstly, that the performance of the tasks of the Data Protection Officer and the performance of other tasks at the controller or its processor are generally not incompatible under the GDPR," but it must be ensured that these other tasks and duties do not lead to a "conflict of interest." Given the significance of this term in common usage, it must be assumed that the Data Protection Officer, in accordance with the objective pursued by Art. 38 para. 6 GDPR, must not be entrusted with tasks or duties that could impair the exercise of his position as Data Protection Officer.

Thus, no tasks or duties may be assigned to the Data Protection Officer that would lead him to determine the purposes and means of processing personal data at the controller or its processor, as the Data Protection Officer must be able to independently oversee these purposes and means.

Whether a specific "conflict of interest" in the sense of Art. 38 para. 6 GDPR exists must be determined on a case-by-case basis, based on an assessment of all relevant circumstances, particularly the

organizational structure of the controller or its processor, and in light of all applicable legal provisions, including any internal regulations of the controller or the processor (cf. para. 40 et seq. therein). Even though the existence of a conflict of interest must always be examined based on the specific case, there are offices and positions in companies where a conflict of interest will regularly be assumed based on the scope of tasks and duties (cf. Brinkmann, Data Protection Officer and Conflicts of Interest - The Risk of Incompatibility with Other Tasks and Offices, BB 2024, 54).

This means that certain positions within the company will be incompatible with the role of the Data Protection Officer (DPO) (cf. König in Knyrim, DatKomm Art 38 GDPR, para. 36). Examples of such positions, where conflicts of interest may be expected, include those in senior management, such as in the executive board, the chief financial officer, and department heads (cf. Bergauer in Jahnel, Commentary on the General Data Protection Regulation Art. 38 GDPR, para. 35). However, even with participation in the company's success, i.e., an economic interest of the Data Protection Officer, for example as a shareholder, a conflict of interest can be assumed (cf. Bergt in Kühling/Buchner, GDPR Art. 38, para. 41).

If a potential conflict of interest is identified, appropriate measures must be taken to ensure that such a conflict does not occur. Depending on the subject matter, size, and structure of an organization, the Article 29 Data Protection Working Party recommends in its guidelines for Data Protection Officers (WP 243 rev.01, available among others at

https://www.dsb.gv.at/europa-internationales/europaeischer_datenschutzausschuss_edsa.html) on pages 19f to address "conflicts of interest" in the position of the Data Protection Officer the following:

- "to identify the positions that are incompatible with the role of a DPO,
 - to establish internal guidelines to avoid conflicts of interest,
 - to provide a general explanation of potential conflicts of interest,
 - to declare that the DPO is not in any conflict of interest regarding their function and thereby raise awareness of this requirement,
 - to include safeguards in the internal guidelines of the organization and ensure that the job advertisement for the position of a DPO or the relevant service contract is formulated sufficiently accurately and precisely to avoid conflicts of interest. In this context, it should be noted that conflicts of interest may take different forms depending on whether the DPO is recruited internally or externally."
- In this case, the person designated by the accused as the Data Protection Officer was also a commercial managing director and thus the body authorized to represent the company externally. Furthermore, the designated person was even a shareholder of the accused until February 17, 2023. The designated person (the managing director and shareholder of the accused) could not be qualified as an independent entity from the accused due to their dual or triple role, which was responsible for monitoring compliance with the GDPR as well as the strategies of the controller or the processor for the protection of personal data, including the assignment of responsibilities, the awareness-raising and training of employees involved in the processing operations, and the related reviews.

could. This excluded an independent control by the Data Protection Officer, which was to be carried out by the management in the present case. Rather, there was a form of self-control that was not accessible to independent objective verification by a third party. The fact that there was a conflict of interest due to the dual role was ultimately no longer disputed by the accused; on September 3, 2024, she stated that the managing director of the accused person was not aware that a conflict of interest existed in this constellation.

Although the accused believes that there is a possibility to resolve the potential conflict of interest through individual measures, it must be countered that no measures—especially not those effective externally—were taken in this case. Merely asserting that the managing director has an appropriate awareness of data protection law does not constitute such a measure and is ultimately not convincing. Rather, it should be assumed that the responsible party inherently possesses an awareness of data protection law.

The objective factual basis is therefore fulfilled.

3.3. Regarding the subjective aspect of the offense

The CJEU has, as already assumed by the Data Protection Authority in its previous case law, now explicitly stated that only violations of provisions of the GDPR that the responsible party commits culpably, i.e., intentionally or negligently, can lead to the imposition of a fine (cf. CJEU of December 5, 2023, C-807/21, para. 68).

However, regarding the subjective aspect of the offense, it should be noted that the requirement of culpability for the imposition of a fine under Article 83 GDPR must be interpreted autonomously at the EU level and assessed particularly in light of the case law of the CJEU. Also, regarding the preliminary question concerning culpability, the CJEU stated that the member states were not granted any discretion by the EU legislator for national regulations in this context, as the material requirements are conclusively regulated in Articles 83(1) to (6) GDPR (cf. also CJEU of December 5, 2023, C-683/21, para. 64 et seq.). Thus, the (national) provision under § 5 VStG concerning culpability does not apply.

Regarding the crucial question of whether a violation was committed intentionally or negligently and can therefore be punished with a fine, the CJEU clarified in its aforementioned judgment that such culpability is already present if the accused could not have been unaware of the unlawfulness of their behavior, regardless of whether they were aware that they were violating the provisions of the GDPR (cf. CJEU C-807/21, para. 76).

Referring to further case law, the CJEU also explicitly clarified that the application of Article 83 GDPR to legal entities does not require an action and not even...

a knowledge on the part of the governing body of this legal entity is required (cf. ECJ of 05.12.2023, C-807/21, para. 77).

Moreover, the ECJ fundamentally stated regarding liability for fines under Art. 83 GDPR that controllers "must not only take appropriate and effective measures, but they must also be able to demonstrate that their processing activities are in compliance with the GDPR and that the measures they have taken to ensure this compliance are also effective. It is this liability that forms the basis for imposing a fine against the controller under Art. 83 GDPR in the event of one of the violations mentioned in Art. 83 para. 4 to 6 GDPR" (ECJ C-807/21, para. 38).

Regarding the violation of the obligation that the controller or processor ensures that no conflicts of interest arise in the performance of other tasks and duties of the data protection officer, the accused was, in any case, subject to a duty of inquiry.

In this context, it is pointed out that extensive information on the data protection officer can be found on the website of the data protection authority (cf. "www.dsb.gv.at"), in particular, reference is made to the "Guideline on Regulation (EU) 2016/679" provided by the data protection authority (available at <https://www.dsb.gv.at/recht-entscheidungen/gesetze-in-oesterreich.html>).

Furthermore, the website of the European Data Protection Board contains comprehensive guidelines on the data protection officer ("Guidelines on the Data Protection Officer of the Art. 29 Data Protection Working Party (WP 243 rev.01), available among others at https://www.dsb.gv.at/europa-internationales/europaeischer_datenschutzausschuss_edsa.html"), which have already been cited multiple times in this decision. These guidelines explain in detail when a conflict of interest is to be assumed and what measures can be taken to address a conflict of interest. Additionally, the European Data Protection Board has also published a guide for small and medium-sized enterprises (SMEs) with a number of recommendations, including specifically regarding the role of the data protection officer (available in German at: https://www.edpb.europa.eu/sme-data-protection-guide/data-protection-officer_de).

Finally, it should also be noted that the wording of Art. 38 para. 6 GDPR clearly indicates that the controller must ensure that there is no conflict of interest in this role.

The accused acted culpably, as they did not engage with their obligations, although it would have been reasonable and possible for them to do so. This would have been easy for the accused, as they claim to possess a corresponding awareness of data protection in the form of their managing director.

The accused could not be unaware of the unlawfulness of her behavior in light of the case law of the CJEU, regardless of whether she was aware that she was violating the provisions of the GDPR (cf.

CJEU C-807/21, paras 76 and 77; CJEU C-683/21, paras 81 and 82 with references). The accused also ultimately acknowledged this and stated that the accused person was not aware that a conflict of interest existed in this constellation. Furthermore, the accused recognized the accusation and apologized for it. Thus, in the present case, there is at least culpability in the form of negligence. This also fulfills the subjective element of the offense.

4.

Regarding the determination of the penalty, the following should be noted:

4.1. General information on penalty assessment

According to Art. 83 para. 1 GDPR, the supervisory authority must ensure that the imposition of fines for violations of the provisions of the GDPR subject to sanctions (Art. 83 para. 4, 5, and 6 GDPR) is effective, proportionate, and deterrent in each individual case. Furthermore, Art. 83 para. 2 GDPR specifies that when deciding on the imposition of a fine and its amount, certain criteria must be duly considered in each individual case.

The data protection authority has applied the EDSA guidelines regarding the calculation of fines under the GDPR (cf. EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, Version 2.1 dated 24.05.2023 – hereinafter referred to as "Fines Guidelines") in the context of penalty assessment.

The provision under § 19 para. 1 VStG does not apply, as the penalty assessment is also conclusively regulated by Art. 83 para. 2 GDPR, leaving no discretion for the member states (cf. CJEU 05.12.23, C-807/21, para. 45; see also the recent decision of the BVwG dated 03.06.2024, GZ: W292 2282284-1).

According to Art. 83 para. 4 GDPR, in the case of the violations mentioned therein, in accordance with para. 2, fines of up to EUR 10,000,000 or, in the case of an undertaking, up to 2% of its total worldwide annual turnover of the preceding financial year are imposed, whichever amount is higher.

The term turnover in Art. 83 para. 4, 5, and 6 GDPR is to be understood in the sense of Art. 2 no. 5 of Directive 2013/34/EU of the European Parliament and of the Council of June 26, 2013, on the annual financial statements, consolidated financial statements, and related reports of certain types of companies, amending Directive 2006/43/EC of the European Parliament and of the Council and repealing Council Directives 78/660/EEC and 83/349/EEC (hereinafter referred to as "Directive 2013/34/EU"). Turnover is the sum of all goods and services sold. Net turnover is the amount resulting from the sale of products and the provision of services after deducting revenue reductions and value-added tax (VAT) as well as other taxes directly associated with turnover (cf. EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, Version 2.1, para. 128 ff).

4.2. In the matter

In light of the Fines Guidelines, the accused is classified regarding her turnover, which she estimated at EUR 4 million for the financial year 2023, and in terms of the imposition of an effective, deterrent, and proportionate fine, into the second-lowest category ("companies with a turnover of EUR 2 million to EUR 10 million"). This classification duly considers the size of the company, particularly to ensure the proportionality of the fine.

The penalty range in the specific case extends according to Art. 83 para. 4 GDPR to an amount of EUR 10,000,000 (static penalty range). The dynamic penalty range (2% of annual turnover) does not apply.

In light of the facts assumed to be proven and considering the nature, severity, and duration of the violation (Art. 83 para. 1 lit. a GDPR), the intent or negligence of the violation (Art. 83 para. 2 lit. b GDPR), as well as the categories of personal data affected by the violation (Art. 83 para. 2 lit. g GDPR), the data protection authority assumes the severity of the infringement ("Seriousness of the infringement") to be low ("low level of seriousness").

Regarding the present facts, in addition to the criteria already considered for the severity, the following mitigating factors were taken into account in the penalty assessment:

- The accused has not committed any relevant violations to date and is thus of good character (cf. Art. 83 para. 2 lit. e GDPR).
- The accused has cooperated in the context of the present investigation and thereby contributed to

the establishment of the truth. The accused admitted to the data protection authority the disregard of her obligations (confession) (cf. Art. 83 para. 2 lit. f and lit. k GDPR). This was particularly taken into account as a mitigating factor.

In determining the penalty, considerations of special prevention and general prevention may also be included according to the consistent case law of the VwGH (cf. VwGH 15.5.1990, 89/02/0093, VwGH 22.4.1997, 96/04/0253, VwGH 29.1.1991, 89/04/0061).

Art. 38 GDPR is intended to enable the data protection officer to fulfill his tasks not only independently but also effectively. The accused has violated this provision – as stated above – in that she did not ensure that the data protection officer did not lead to a conflict of interest in the performance of other tasks and duties. The imposition of the specific

The fine was therefore necessary in any case in terms of general prevention, to raise awareness among those responsible and processors in connection with their appointment of a data protection officer.

The data protection authority assumes that the accused will refrain from committing such an offense again in the future. Therefore, in the opinion of the data protection authority, there are no specific preventive reasons present.

The specific fine imposed in the amount of EUR 5,000 appears to be appropriate in relation to the value of the act committed, measured against the available penalty range of Art. 83 para. 4 GDPR, in terms of the nature of the offense and culpability. A (still) lower amount would not meet the central criteria of Art. 83 para. 1 GDPR (effective, deterrent, and proportionate).